

INCIDENT RESPONSE REPORT

Cobalt Strike & LockBit Ransomware Intrusion

Case Reference: IR-2025-001 | Classification: TLP:WHITE

Field	Details
Analyst	Riya MSc Cybersecurity, MTU Cork
Report Date	June 2026
Incident Type	Ransomware — LockBit 3.0
Threat Actor	LockBit Ransomware Group (suspected affiliate)
Dwell Time	11 days (initial access to ransomware deployment)
Severity	CRITICAL
Source	The DFIR Report (January 2025) — thedfirreport.com

1. Executive Summary

This report documents the analysis of a real-world ransomware intrusion attributed to a LockBit affiliate, originally published by The DFIR Report in January 2025. The incident demonstrates a sophisticated, multi-stage attack spanning 11 days from initial access to full ransomware deployment across an enterprise network.

The attacker gained initial access through a trojanized installer — a file named setup_wm.exe disguised as a Windows Media Configuration Utility, downloaded from a malicious website. Over the following 11 days, the attacker deployed Cobalt Strike for command and control, used multiple tools to move laterally across the network, exfiltrated data using Rclone to Mega.io, and ultimately deployed LockBit 3.0 ransomware across all reachable Windows systems.

This incident is a textbook example of double extortion ransomware — the attacker stole data before encrypting it, meaning the victim faced both the threat of data loss and public exposure of sensitive information.

Incident at a Glance

11 Days Dwell Time	LockBit 3.0 Ransomware Family	10+ Tools Attacker Arsenal	Double Extortion Used
------------------------------	---	--------------------------------------	---------------------------------

2. Incident Timeline

The following table maps the full attack chain in chronological order, from initial infection to ransomware deployment.

Day	Phase	Activity	MITRE Technique
Day 0	Initial Access	User downloads and executes setup_wm.exe — a trojanized installer disguised as Windows Media Configuration Utility from accessservicesonline[.]com	T1566.002 — Spearphishing Link T1204.002 — Malicious File
Day 0	Execution & C2	Cobalt Strike Beacon deployed. Attacker establishes persistent Command & Control channel to remote infrastructure.	T1059.003 — Windows Command Shell T1071.001 — Web Protocols C2
Day 1–2	Persistence	SystemBC and GhostSOCKS deployed as SOCKS5 proxies. Scheduled Tasks and Registry Run Keys created to survive reboots.	T1053.005 — Scheduled Task T1547.001 — Registry Run Keys
Day 2–5	Discovery	Attacker runs nltest to find domain controllers, Seatbelt for host enumeration, SharpView for AD reconnaissance, and a custom check.exe tool.	T1018 — Remote System Discovery T1069 — Permission Groups Discovery T1087 — Account Discovery
Day 5–9	Lateral Movement	Attacker moves across the network using PsExec, WMI, RDP, and SMB. Stolen credentials used to authenticate as legitimate users on other machines.	T1021.002 — SMB/Windows Admin Shares T1021.001 — Remote Desktop Protocol T1047 — WMI
Day 9–10	Exfiltration	Rclone used to exfiltrate sensitive data to Mega.io via FTP. This is the data theft component of double extortion — stolen before encryption begins.	T1048 — Exfiltration Over Alternative Protocol T1567.002 — Exfiltration to Cloud Storage
Day 11	Impact	LockBit 3.0 deployed across all reachable Windows systems via PsExec, WMI, and BITSAdmin. Windows Defender disabled, Volume Shadow Copies deleted, desktop wallpaper changed, ransom note dropped.	T1486 — Data Encrypted for Impact T1490 — Inhibit System Recovery T1562.001 — Disable Security Tools

3. Attacker Tools & Techniques

The attacker used a sophisticated toolkit combining legitimate system administration tools with purpose-built malware. This is a classic Living Off the Land (LotL) strategy — using tools that already exist on Windows systems to blend in with normal activity.

Tool	Category	MITRE Technique	Purpose
Cobalt Strike	C2 Framework	T1071.001	Primary command and control — attacker's remote access tool
SystemBC	Proxy Malware	T1090.002	SOCKS5 proxy to tunnel traffic and hide C2 communications
GhostSOCKS	Proxy Malware	T1090.002	Additional SOCKS proxy for redundant C2 channels
nltest	Discovery (built-in)	T1018	Native Windows tool used to enumerate domain controllers
Seatbelt	Recon Tool	T1082	Host enumeration — OS info, installed software, credentials
SharpView	AD Recon	T1087.002	Active Directory reconnaissance — users, groups, GPOs
Psexec	Lateral Movement	T1021.002	Remote execution on other machines using stolen credentials
WMI	Lateral Movement (built-in)	T1047	Native Windows tool abused for stealthy remote execution
Rclone	Exfiltration	T1567.002	Data theft to Mega.io cloud storage before encryption
LockBit 3.0	Ransomware	T1486	Final payload — encrypts all reachable Windows file systems

4. Indicators of Compromise (IOCs)

The following indicators were identified during analysis. These should be added to firewall blocklists, EDR exclusion rules, and SIEM watchlists to detect or prevent similar intrusions.

Type	Indicator	Context
Domain	accessservicesonline[.]com	Malicious download site — initial access vector

Filename	setup_wm.exe	Trojanized installer — disguised as Windows Media tool
Tool	rclone.exe	Legitimate tool abused for data exfiltration to Mega.io
Destination	mega[.]io / Mega.nz FTP endpoints	Cloud storage used for stolen data staging
Process	schtasks.exe spawned by powershell.exe	Persistence mechanism — detectable via EventCode 4698
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion\Run	Registry Run Key — malware auto-starts on login
Behaviour	vssadmin delete shadows /all /quiet	Volume Shadow Copy deletion — removes Windows backups

5. MITRE ATT&CK Mapping

The attack maps to the following MITRE ATT&CK tactics and techniques across the full kill chain:

Tactic	Technique ID	Technique Name	Observable
Initial Access	T1204.002	Malicious File	setup_wm.exe execution
Execution	T1059.003	Windows Command Shell	cmd.exe spawned by beacon
Persistence	T1053.005	Scheduled Task	EventCode 4698 — task created
Persistence	T1547.001	Registry Run Keys	HKCU Run key modified
Defence Evasion	T1562.001	Disable Security Tools	Defender GPO modified
Credential Access	T1003	OS Credential Dumping	Credentials extracted from memory
Discovery	T1018	Remote System Discovery	nltest /dclist
Lateral Movement	T1021.002	SMB/Admin Shares	PsExec over SMB
Lateral Movement	T1047	WMI Execution	WMI remote process creation
Exfiltration	T1567.002	Exfil to Cloud Storage	Rclone → Mega.io
Impact	T1486	Data Encrypted for Impact	LockBit 3.0 deployed

Impact	T1490	Inhibit System Recovery	VSS copies deleted
--------	-------	-------------------------	--------------------

6. Detection Opportunities

The following detections, mapped to the SIEM rules built in this portfolio's home lab, would have identified attacker activity at multiple stages of the kill chain:

Attack Stage	Detection Rule	Splunk SPL Query	EventCode	Severity
Persistence	Scheduled task created outside business hours	index=main EventCode=4698	4698	High
Execution	PowerShell spawning schtasks.exe	EventCode=4688 parent=powershell child=schtasks	4688	Critical
Credential Access	Multiple failed logins — brute force indicator	EventCode=4625 count > 5	4625	High
Lateral Movement	Admin login from unexpected source IP	EventCode=4624 LogonType=3	4624	Medium
Defence Evasion	Scheduled task disabled or modified	EventCode=4701 OR EventCode=4702	4701/4702	High

7. Remediation Recommendations

The following recommendations are prioritised by impact. Critical items should be addressed within 24 hours of incident containment; High within 7 days.

#	Recommendation	Priority	Timeframe
1	Isolate all affected systems and revoke all active credentials immediately. Assume all domain credentials are compromised.	Critical	24 hours
2	Restore from clean backups that predate the initial infection (Day 0). Verify backup integrity before restoration.	Critical	24–48 hrs
3	Block the initial access domain (accessservicesonline[.]com) and Mega.io FTP endpoints at the firewall.	Critical	24 hours
4	Deploy application allowlisting to prevent unauthorised tools (Rclone, PsExec, Seatbelt) from executing.	High	7 days
5	Implement MFA on all remote access (RDP, VPN) to prevent lateral movement using stolen credentials.	High	7 days

6	Enable Windows audit policies for Process Creation (4688), Scheduled Tasks (4698), and Registry modifications (4657) across all endpoints.	High	7 days
7	Deploy a SIEM with detection rules for the attack patterns identified in Section 6. Prioritise scheduled task and parent-child process rules.	High	30 days
8	Conduct user awareness training focused on trojanized installers and suspicious download sources.	Medium	30 days

8. Lessons Learned

What the attacker did well

- Used a trojanized legitimate-looking installer to bypass user suspicion — most users would not question a file named setup_wm.exe
- Blended in with normal Windows tools (WMI, PsExec, schtasks) — known as Living off the Land, making detection harder
- Maintained multiple redundant C2 channels (Cobalt Strike + SystemBC + GhostSOCKS) so losing one didn't end the intrusion
- Deleted Volume Shadow Copies before encrypting — removing the victim's easiest recovery option
- Stole data before encrypting it — double extortion maximises leverage over the victim

Where defenders could have intervened

- Day 0 — Web filtering or DNS blocking could have prevented the download from accessservicesonline[.]com
- Day 0 — EDR with behavioural detection should have flagged setup_wm.exe on execution
- Day 1–2 — Scheduled task creation (EventCode 4698) should have triggered an alert in the SIEM
- Day 5–9 — Lateral movement via PsExec generates distinctive EventCode 4688 events — detectable with the rules built in this lab
- Day 9–10 — Rclone uploading gigabytes of data to Mega.io should have triggered a data loss prevention (DLP) alert
- Day 11 — Mass file encryption generates enormous I/O spikes detectable by EDR tools

Key takeaway

An 11-day dwell time means the attacker was visible in logs for nearly two weeks before causing damage. With the SIEM detection rules built in this portfolio, three of the attack techniques (scheduled task creation, suspicious process spawning, and brute force credential

use) would have generated alerts within hours of occurring. Early detection is the difference between a contained incident and a full ransomware deployment.

9. Analyst Notes

This report was produced as part of a blue team cybersecurity portfolio, based on the publicly available incident report published by The DFIR Report (January 2025). The analysis demonstrates applied knowledge of:

- Incident response methodology — structured timeline, IOC extraction, and formal reporting
- MITRE ATT&CK framework — mapping real attacker behaviour to standardised technique IDs
- SIEM detection engineering — connecting observed attack techniques to Splunk SPL detection rules
- Threat intelligence — understanding attacker tooling, motivation, and double extortion ransomware economics

The detection rules referenced in Section 6 are operational in the home lab SIEM environment documented in this portfolio. All three primary detections (EventCode 4698, 4688 parent-child, and 4625 brute force) were validated against real simulated attack traffic generated using Atomic Red Team.

End of Report — IR-2025-001

Source: The DFIR Report, January 2025 | thedfirreport.com/2025/01/27/cobalt-strike-and-a-pair-of-socks-lead-to-lockbit-ransomware/